

AIM

RD.060 AUDIT AND CONTROL REQUIREMENTS

<Company Long Name>

<Subject>

Author: <Author>
Creation Date: February 12, 1999
Last Updated: August 15, 2025
Document Ref: <Document Reference Number>
Version: DRAFT 1A

Approvals:

<Approver 1>

<Approver 2>

ORACLE®

Copy Number _____

Document Control

Change Record

Date	Author	Version	Change Reference
12-Feb-99	<Author>	Draft 1a	No Previous Document

Reviewers

Name	Position

Distribution

Copy No.	Name	Location
1	Library Master	Project Library
2		Project Manager
3		
4		

Note To Holders:

If you receive an electronic copy of this document and print it out, please write your name on the equivalent of the cover page, for document control purposes.

If you receive a hard copy of this document, please write your name on the front cover, for document control purposes.

Contents

Document Control	ii
Audit and Control Requirements Questionnaires	1
User Security Requirements	9
Open and Closed Issues for this Deliverable	10
Open Issues.....	10
Closed Issues	10

Audit and Control Requirements Questionnaires

Separation of Duties	Answer	Comments
Are the roles of user, developer, and computer operator separate and distinct?		
Is the developer able to submit input or have access to the master files?		
In sensitive programs, does the developer have access to data file except under the most extraordinary circumstances?		
If developers have access to data files, are controls in place to prevent and detect irregularities?		
Can the operations group input data to a production run without detection by the controls function?		
Have critical transactions been identified by the owner?		
Do users, support developers, operations personnel, and DBAs have access to production libraries?		

Sensitive Programs	Answer	Comments
Has the application owner, with the assistance of programming development management, conducted a detail review of the programs identified as sensitive?		
Is documentation available that states: Who can access sensitive programs? Who has accessed sensitive programs? When programs were executed? Whether the correct programs were executed?		
Is there a written control strategy for normal production executions and making modifications to sensitive programs?		
Are all new sensitive programs or major changes to existing programs reviewed by management?		
Do development or maintenance developers have update access to production version of sensitive program source of load modules?		
Do procedures exist to handle required emergency access?		
Have all the appropriate programs been identified as sensitive?		
Is access to the libraries restricted?		
Are procedures in place for changes to be approved by an independent developer before implementation?		
Does the developer have update access to the production load library?		
Are the corresponding C-scripts adequately protected?		
Do operations control personnel have update authority to production libraries containing sensitive programs?		
Is access to the source code restricted?		
Has the owner limited access authority to one person making specific changes and promoting the changes version to production status?		
Will the application tables be kept secure so that they can be updated only with proper management approval?		
Is access to production data sets properly authorized?		
Is access to source and load libraries and to physical stock of negotiable instruments controlled?		

Sensitive Programs	Answer	Comments
Are unauthorized attempts being tracked and eliminated?		
Is a log maintained by the supplier of services of all access to sensitive programs, and is it reviewed by owner management?		

Logical Access Controls	Answer	Comments
Have all application data sets been identified, reviewed, and assigned a level of classification appropriate with their value to <Company Short Name>?		
Review the system flow diagram to better understand all master file inputs, and outputs, including transaction files used by sensitive programs.		
Are passwords changed at least every 180 days?		
Is there a list of users having authorized access?		
Is user password marked so as not to be displayed during key-in?		
Have all users been authorized by the data owner?		
Are an excessive number of users authorized for update capability?		
Are owners of application data sets receiving and reviewing security reports to monitor file usage, including security violations?		
Are data files protected from unauthorized access?		
Do all users have a business access need?		
Have all users with access been approved by management?		
Are security reports generated for management review?		

Vital Records and Disaster Recovery	Answer	Comments
Is a current copy of the applications' master files stored off premises?		
Is there a documented, approved, and current disaster recovery plan in place for the application?		
Has the owner identified any process as a vital business process?		
Has the disaster recovery plan been tested or simulated at a backup site in the last 12 months to verify whether the owner is prepared to recover a vital business process?		
Are copies of source modules, documentation, and computer processing instructions(error procedures, checkpoint restart procedures, and so on) stored off-premises?		
Does a record retention schedule exist for vital records?		
Are waste disposal procedures in place to ensure disposal of confidential data in a proper manner (for example, aborted computer runs, and so on)?		
Have service level agreements with functions that are considered essential to the recovery of vital business processes been negotiated?		

Change Control	Answer	Comments
Is there a documented method for processing and controlling work requests on program and systems problems?		
Does a work request (backlog) system exist that would facilitate the planning, tracking, and monitoring of the application development and maintenance process?		
Does the owner properly authorize all changes properly?		
Do controls prevent an individual from making unauthorized and undetected changes to programs?		
Are development and systems support personnel prevented from accessing production libraries?		
Do emergency change and recovery procedures ensure that the integrity of production libraries is not compromised?		
Are controls in place to prevent unauthorized and undetected modification of job control language?		
Are controls in place over changes to system software?		
Are changes printed to reports for use as an audit trail?		
Are reports independently reviewed?		
Are all production programs run from production libraries?		
Do all production source and load modules on the production source load and job control language libraries have a proper authorization for being there?		
Can all production program promotions be accounted for (for example, moving from test to production libraries, and so on)?		
Is access authorization reviewed for current business needs?		
Do written standards and guidelines exist to ensure that all new/changed programs are fully tested?		
Are test cases and test results documented and cross-referenced to control points?		
Are users/owners sufficiently involved in the definition of test data, review of results and formal acceptance to ensure production quality and to minimize implementation difficulties?		
Do procedures exist to control the authorized use of production live data for testing purposes?		
If operations has developed application standards, do they require validation of adherence through formal testing before acceptance?		
Do procedures exist to identify, control, and track program trouble reports?		
Test Data:		
Was every relevant functional capability of the application tested at least once?		
Were different combinations used?		
Were error conditions used?		
Are the results of each test case documented?		
If there were problems, have they been resolved?		
Were occasionally used features tested (for example, annual reports, special updates, and so on)?		
Are controls and audit trails functioning?		
Is action required when controls detect impropriety or error?		
Were manual controls tested through transaction processing?		
Have date conversion and interfacing programs been tested?		
Was a stress done to assess the impact of high volumes on control and audit ability?		
Was regression testing done?		
Was the application tested with live data?		
Was a parallel test made?		
Did the application provide an adequate service level regardless of volume?		

Change Control	Answer	Comments
Does the system test show test result for the following areas: Run-to-run totals? Input/output controls? Recovery procedures? Logging?		
Were users adequately involved at all levels of testing?		
Has the user/owner developed acceptance criteria for system test?		
To what extent could systems, which interface with the application, affect control and auditability features?		
Were the interfaces adequately tested?		

Transaction Origination Controls	Answer	Comments
Are input documents designated with preprinted information requirements which include spaces for authorization?		
Are they all accounted for via control totals?		
Are procedures in place to ensure source data is properly authorized before processing (manual or Transaction ID) ?		
Is the data processing department separate from functional users?		
Within each user area, is source data generation separate from transaction recording?		
Does each transaction to be entered into the system have a code which uniquely identifies that transaction (serial, sequence number, or transaction code)?		
Is a unique user identification code used to restrict the transaction the user may process and files the user may access?		
Is the frequency of change reasonable? Explained?		
Is a log established in the primary user area to record flow of transactions between organizations processing source document to identify missing items and maintain accountability for transaction origination controls?		
Does the user maintain an error log to record and monitor document errors reported by IS input preparation function, ensure errors are corrected, and verify that resubmitted data is the same as the source?		
Are source documents properly stored with controlled access to sensitive blank forms?		
Are terminals secured to prevent unauthorized access, password protected, and lockwords used for file protection?		
Are reports generated showing a summary of online data entry (user ID, terminal address)?		
Are logs (hardware control feature) used to record all transactions processed?		
Are edit and validation controls the same for the original transactions as for rejected data?		
Are system access passwords, user identification codes, and file and program access passwords restricted to those authorized to use them?		
Are procedures such that terminal operators cannot use the terminal to modify production programs or system software?		
Do edit and validation controls prevent duplicate entry?		
Are recorded counts/control totals reconciled to control totals of the incoming batch of data?		
Do schedules and logs exist to determine that all transaction have been received and entered in time?		
Are controls in place to ensure cancellation of source documents to prevent reuse and accidental duplication?		
Are batch totals developed in user departments to be submitted to IS in form of batch header totals?		
Are preprocessing edit error listings used to remove errors before further processing and are procedures in place to ensure corrections and reentry in a timely manner?		
Is data validated when converted from human readable to computer form (for example, keypunch verification, and so on)?		
Are self-checking digits used for key fields (for example, account numbers and so on)?		

Communication Controls	Answer	Comments
Is there an electronic identification code built into the terminal to prevent unauthorized terminals from entering the system?		
Are certain transactions restricted to a specific group of terminals?		
Is each terminal identified by user passwords?		
Is a call back procedure used for terminals with dial up access?		
Are procedures, policies, and day-to-day activities supporting security and the safeguards to the data communication network reviewed regularly?		
Are validity checks used (such as a parity check on errors) in transmitted data?		
Is there adequate monitoring of invalid access attempts to detect unauthorized activity?		
Do redundancy checks exist for re-transmission of data confirmation?		
Are encryption techniques used during transmission of data classified as confidential?		
Is detection control with re-transmission in place (redundancy checks to detect transmission errors)?		
Does re-transmission occur when receiving unit determines error message?		
Are validations made to ensure messages are checked for valid addresses, heading, and format?		
Is a complete list of line usage records and individual messages maintained for audit purposes?		
Is there a procedure for periodically re-validating authorized users?		
Are numbers assigned automatically for all messages in and out of the computer system?		
Are there reports which summarize transaction activity by type and terminal?		
Are these reports reviewed for any unusual activity?		
Does message sequence numbering provide for traceable message log and allow for balancing of all incoming and outgoing messages between computer and the terminal?		
Are errors in transmission of message logged, number of time each type occurs, total errors, and so on?		

Processing Controls	Answer	Comments
Are transaction codes used to direct the transaction to the proper portion of the application program section for testing?		
Is there a system of automated or manual controls including balancing the entire system, balancing between systems, and balancing and reconciling other files used (for example, program-to-program record, dollar totals, run-to-run control totals, comparison of input transactions to a pre-determined total count, or count of output transactions, and so on)?		
Do validation programs match the transaction record key and major input data elements against corresponding fields in a master file or appropriate tables?		
Do data validation programs compare data in different fields to see whether they represent an appropriate and valid combination?		
Do data validation programs test that the same transaction had not been previously entered into the system?		
Is automated or pre-programmed editing in place to ensure reasonable checks for input data, completeness of data, consistency checks?		
Are the number of opening records balanced against daily changes and closing balance?		
Are computer operator instructions in use to limit operator intervention and prohibit unauthorized access to the computer system by the operator?		
Is a log of unscheduled or unusual interventions maintained by the operators?		
Are messages printed to enable operators to review messages?		
Is a machine utilization report, which identifies job run, the operator present, and any unusual conditions encountered during the run, in place for management review?		
Do audit trails exist which would allow end users to follow flow of data through applications?		
Do error reports exist which describe error conditions?		
Is there a discrepancy report used to ensure handling of errors, correction, and re-entry in a timely manner, shows aging of errors, and frequency of error types?		
Is a report of error trends by type, source, and frequency maintained?		
Does management review all computer reports to resolve exceptions as they occur?		
Are error procedures defined in the users manual by type of error condition and correction procedures defined clearly?		
Is a register provided to the user showing changes to master file data or programmed data?		
Is there a report which flags out-of-balance conditions in batch totals and heading totals which are then sent back to the originating location?		
Is the application currently in balance?		
Are out of balances resolved promptly?		
Can an out of balance condition be explained?		
Is there a management review of out of balance conditions?		
If the application being reviewed uses a database management system, have procedures been established to balance the database with control totals?		
Have procedures been developed to define the reconciliation process?		

Output Controls	Answer	Comments
Are output controls reconciled with input totals before release from data processing to user (for example, header/trailer, records with control totals, hash totals, and so on)?		
Can totals be changed and reconciliations affected through transactions/other interventions?		
Are all reconcilable items aged and reported to the user?		
Are transactions used to change totals and effect reconciliation?		
Does the report cover sheet clearly indicate recipients name and location?		
Does the report reflect a classification?		
Is a log maintained of all reports distributed (time, date, job name, dispatcher, and quantity)?		
Does a report exist showing schedules of distribution and follow up action when delay occurs?		
Are reports reconcilable to the data that they contain?		
Is there a periodic review of all system reports received by the user for continued need?		
Is there a process to grant access for reporting/query needs?		
Is distribution of reproduced copies limited to an authorized number?		
Are lockboxes used for report distribution to users?		
Are output reports reviewed for completeness, proper formatting, and correctness?		

Documentation	Answer	Comments
Does application documentation exist?		
Is it current and does it comply with location standards?		
Does an overall statement of purpose exist?		
Has the system design accomplished this stated purpose?		
Do system flowcharts show the flow of transactions from the first inputs to the final outputs, including all input data sets, sorts, exception reports, control points, and other data transactions?		
Does documentation include record layouts of the data included in tape, disk, and so on?		
Does documentation include a description of the jobs necessary to run the system?		
Are operating procedures documented properly?		
Does the documentation include detailed instructions about the recovery or rerun procedures at crucial points in the job?		
Does the development documentation substantiate that auditability and control specs were defined and built into the application?		
Does the documentation contain a description of error messages generated by the system, the reason for errors, and suggested corrective action to be taken?		
Are the control points identified on the system flowchart?		
Is the user documentation adequate?		

[illegible]

Open and Closed Issues for this Deliverable

Open Issues

ID	Issue	Resolution	Responsibility	Target Date	Impact Date

Closed Issues

ID	Issue	Resolution	Responsibility	Target Date	Impact Date